

Password spray investigation

kenwith

22–28 minutes

This article provides guidance on identifying and investigating password spray attacks within your organization and taking the required remediation actions to protect information and minimize further risks.

This article contains the following sections:

- **Prerequisites:** Covers the specific requirements you need to complete before starting the investigation. For example, logging that should be turned on, roles and permissions required, among others.
- **Workflow:** Shows the logical flow that you should follow to perform this investigation.
- **Checklist:** Contains a list of tasks for each of the steps in the flow chart. This checklist can be helpful in highly regulated environments to verify what you did or simply as a quality gate for yourself.
- **Investigation steps:** Includes a detailed step-by-step guidance for this specific investigation.
- **Recovery:** Contains high-level steps on how to recover/mitigate from a password spray attack.
- **References:** Contains more reading and reference materials.

Before starting the investigation, make sure you have completed the setup for logs and alerts and other system requirements.

For Microsoft Entra monitoring, follow our recommendations and guidance in our [Microsoft Entra SecOps Guide](#).

By default, the Microsoft Active Directory Federation Services (ADFS) in Windows Server 2016 has a basic level of auditing enabled. With basic auditing, administrators can see five or less events for a single request. Set logging to the highest level and send the AD FS (& security) logs to a SIEM to correlate with AD authentication and Microsoft Entra ID.

To view the current auditing level, use this PowerShell command:

Get-AdfsProperties

```
PS C:\Users\Administrator> Get-AdfsProperties

AcceptableIdentifiers      : {}
AddProxyAuthorizationRules : exists([Type == "http://schemas.microsoft.com/ws/2008/06/identity/claims/groupsid",
Value == "S-1-5-32-544", Issuer =~ "AAD AUTHORITY$"]) => issue(Type =
"http://schemas.microsoft.com/authorization/claims/permit", Value = "true");
c:[Type ==
"http://schemas.microsoft.com/ws/2008/06/identity/claims/primarysid", Issuer =~ "AAD
AUTHORITY$" ]
=> issue(store="_ProxyCredentialStore", types=("http://schemas.mic
rosoft.com/authorization/claims/permit"), query="isProxyTrustManagerSid({0})",
param=c.Value );
c:[Type ==
"http://schemas.microsoft.com/ws/2008/06/identity/claims/proxytrustid", Issuer =~
"ASELF AUTHORITY$" ]
=> issue(store="_ProxyCredentialStore", types=("http://schemas.mic
rosoft.com/authorization/claims/permit"), query="isProxyTrustProvisioned({0})",
param=c.Value );
ArtifactDbConnection       : Data Source=np:\\.\pipe\microsoft#wid\tsql\query;Initial
Catalog=AdfsArtifactStore;Integrated Security=True
AuthenticationContextOrder : {urn:oasis:names:tc:SAML:2.0:ac:classes:Password,
urn:oasis:names:tc:SAML:2.0:ac:classes:PasswordProtectedTransport,
urn:oasis:names:tc:SAML:2.0:ac:classes:TLSClient,
urn:oasis:names:tc:SAML:2.0:ac:classes:X509...}
AuditLevel                  : {Basic}
AutoCertificateRollover     : True
CertificateCriticalThreshold : 2
CertificateDuration          : 365
```

This table lists the auditing levels that are available.

Audit level	PowerShell syntax	Description
None	Set-AdfsProperties -AuditLevel None	Auditing is disabled and no events are logged
Basic (Default)	Set-AdfsProperties -AuditLevel Basic	No more than five events will be logged for a single request

Audit level	PowerShell syntax	Description
Verbose	Set-AdfsProperties -AuditLevel Verbose	All events are logged. This level logs a significant amount of information per request.

To raise or lower the auditing level, use this PowerShell command:

```
Set-AdfsProperties -AuditLevel <None | Basic | Verbose>
```

1. Select **Start**, navigate to **Programs > Administrative Tools**, and then select **Local Security Policy**.
2. Navigate to the **Security Settings\Local Policies\User Rights Management** folder, and then double-click **Generate security audits**.
3. On the **Local Security Setting** tab, verify that the ADFS service account is listed. If it isn't present, select **Add User or Group** and add it to the list, and then select **OK**.
4. To enable auditing, open a command prompt with elevated privileges and run the following command:

```
auditpol.exe /set /subcategory:"Application Generated" /failure:enable /success:enable
```
5. Close **Local Security Policy**.
6. Next, open the ADFS Management snap-in, select **Start**, navigate to **Programs > Administrative Tools**, and then select **ADFS Management**.
7. In the **Actions** pane, select **Edit Federation Service Properties**.

8. In the **Federation Service Properties** dialog box, select the **Events** tab.
9. Select the **Success audits** and **Failure audits** check boxes.
10. Select **OK** to finish and save the configuration.

The Microsoft Entra Connect Health for ADFS agent allows you to have greater visibility into your federation environment. It provides you with several preconfigured dashboards like usage, performance monitoring and risky IP reports.

To install ADFS Connect Health, go through the [requirements for using Microsoft Entra Connect Health](#), and then install the [Azure ADFS Connect Health Agent](#).

After Microsoft Entra Connect Health for ADFS is configured, you should monitor and set up alerting using the ADFS Risky IP report workbook and Azure Monitor. The benefits of using this report are:

- Detection of IP addresses that exceed a threshold of failed password-based logins.
- Supports failed logins due to bad password or due to extranet lockout state.
- Supports enabling alerts through Azure Alerts.
- Customizable threshold settings that match with the security policy of an organization.
- Customizable queries and expanded visualizations for further analysis.
- Expanded functionality from the previous Risky IP report, which is deprecated as of January 24, 2022.

To set up SIEM tool alerts, go through the tutorial on [out of the box alerting](#).

Connect the Security Information and Event Management (SIEM) tool to Microsoft Defender for Cloud Apps, which currently supports Micro Focus ArcSight and generic common event format (CEF).

For more information, see [Generic SIEM Integration](#).

You can connect SIEM with the Microsoft Graph Security API by using any of the following options:

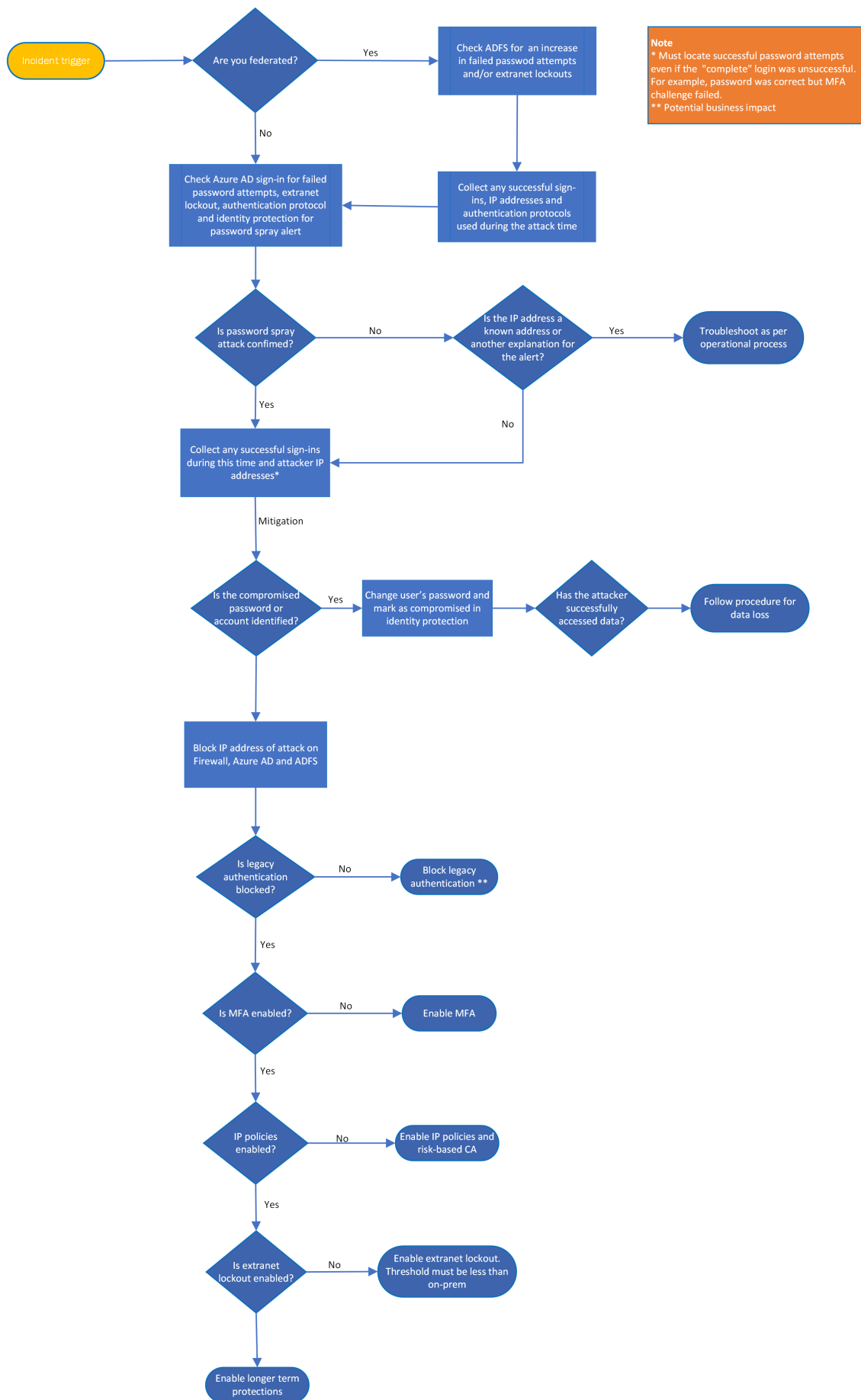
- **Directly using the supported integration options** – Refer to the list of supported integration options like writing code to directly connect your application to derive rich insights. Use samples to get started.
- **Use native integrations and connectors built by Microsoft partners** – Refer to the Microsoft Graph Security API partner solutions to use these integrations.
- **Use connectors built by Microsoft** – Refer to the list of connectors that you can use to connect with the API through various solutions for Security Incident and Event Management (SIEM), Security Response and Orchestration (SOAR), Incident Tracking and Service Management (ITSM), reporting, and so on.

For more information, see [Security solution integrations using the Microsoft Graph Security API](#).

You can also use the Splunk platform to set up alerts.

- Watch this video tutorial on how to create [Splunk alerts](#).
- For more information, see [Splunk alerting manual](#).

The following flowchart shows the password spray investigation workflow.



You can also:

- Download the password spray and other incident response

playbook workflows as a [PDF](#).

- Download the password spray and other incident response playbook workflows as a [Visio file](#).
- Received a trigger from SIEM, firewall logs, or Microsoft Entra ID
- Microsoft Entra ID Protection Password Spray feature or Risky IP
- Large number of failed sign-ins (Event ID 411)
- Spike in Microsoft Entra Connect Health for ADFS
- Another security incident (for example, phishing)
- Unexplained activity, such as a sign-in from unfamiliar location or a user getting unexpected MFA prompts
- What is being alerted?
- Can you confirm this attack is a password spray?
- Determine timeline for attack.
- Determine one or more IP addresses of the attack.
- Filter on successful sign-ins for this time period and IP address, including successful password but failed MFA
- Check [MFA reporting](#)
- Is there anything out of the ordinary on the account, such as new device, new OS, new IP address used? Use Defender for Cloud Apps or Azure Information Protection to detect suspicious activity.
- Inform local authorities/third parties for assistance.
- If you suspect a compromise, check for data exfiltration.

- Check associated account for suspicious behavior and look to correlate to other possible accounts and services as well as other malicious IP addresses.
- Check accounts of anyone working in the same office/delegated access - password hygiene (make sure they aren't using the same password as the compromised account)
- Run ADFS help

Check the [References](#) section for guidance on how to enable the following features:

- [Block IP address of attacker](#) (keep an eye out for changes to another IP address)
- Changed user's password of suspected compromise
- [Enable ADFS Extranet Lockout](#)
- [Disabled Legacy authentication](#)
- [Enabled Azure Identity Protection](#) (sign in and user risk policies)
- [Enabled MFA](#) (if not already)
- [Enabled Password Protection](#)
- [Deploy Microsoft Entra Connect Health for ADFS](#) (if not already)
- Tag bad IP address in Defender for Cloud Apps, SIEM, ADFS, and Microsoft Entra ID
- Check for other forms of mailbox persistence such as forwarding rules or other delegations added
- [MFA as primary authentication](#)
- [Configure SIEM integrations with Cloud](#)
- Configure alerting - Identity Protection, ADFS Health Connect, SIEM, and Defender for Cloud Apps

- Lessons learned (include key stakeholders, third parties, communication teams)
- Security posture review/improvements
- [Plan to run regular attack simulators](#)

You can also download the password spray and other incident playbook checklists as an [Excel file](#).

Let's understand a few password spray attack techniques before proceeding with the investigation.

Password compromise: An attacker guessed the user's password but hasn't been able to access the account due to other controls such as multifactor authentication (MFA).

Account compromise: An attacker guessed the user's password and gained access to the account.

As the first step, you need to check what authentication type is used for a tenant/verified domain that you're investigating.

To obtain the authentication status for a specific domain name, use the [Get-MgDomain](#) PowerShell command. Here's an example:

```
Connect-MgGraph -Scopes "Domain.Read.All"  
Get-MgDomain -DomainId "contoso.com"
```

If the authentication is federated, then successful sign-ins are stored in Microsoft Entra ID. The failed sign-ins are in their Identity Provider (IDP). For more information, see [AD FS troubleshooting and event logging](#).

If the authentication type is managed–cloud-only, password hash sync (PHS), or pass-through authentication (PTA)—then successful and failed sign-ins are stored in the Microsoft Entra sign-in logs.

Note

The [Staged Rollout](#) feature allows the tenant domain name to be federated but specific users to be managed. Determine if any users are members of this group.

- The [RiskyIP report](#) provides suspect IPs and date/time. Notifications should be enabled.
- Also check the [federated sign-ins investigation from the Phishing playbook](#)
- This setting is a requirement for ADFS Connect Health, but it can be enabled independently
- See how to [enable ADFS Health Connect](#))
- Also check the [Federated sign-ins investigation from the Phishing playbook](#)

To check whether you're storing and correlating logs in a Security Information and Event Management (SIEM) or in any other system:

- Log analytics- prebuilt queries
- Microsoft Sentinel- prebuilt queries
- Splunk – prebuilt queries
- Firewall logs
- UAL if > 30 days

It's important that you understand the logs that you're seeing to be able to determine compromise. Here are quick guides to understanding Microsoft Entra sign-ins and MFA reporting:

- [MFA reporting](#)
- [Understanding Sign Ins](#)

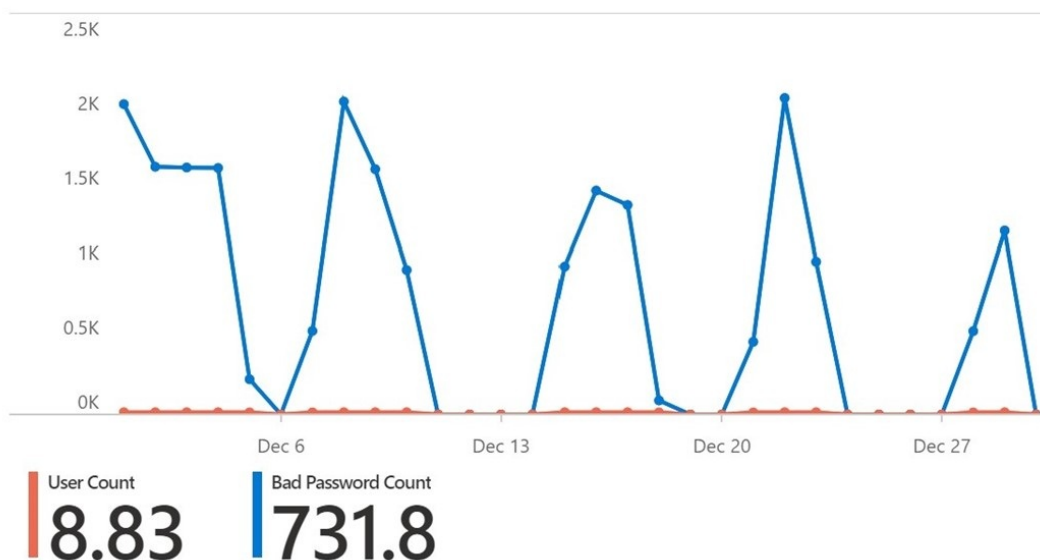
An incident trigger is an event or a series of events that causes predefined alert to trigger. An example is the number of bad password attempts above your predefined threshold. Here are further examples of triggers that can be alerted in password spray attacks and where these alerts are surfaced. Incident triggers include:

- Users
- IP
- User agent strings
- Date/time
- Anomalies
- Bad password attempts

Bad Password Attempts

contoso.net

From last 30 days

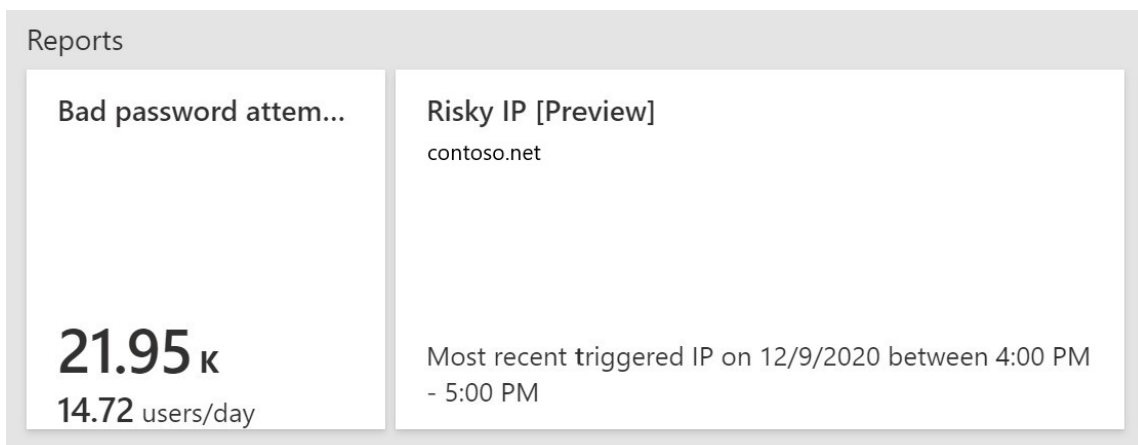


Top 50 users in past week

Unusual spikes in activity are key indicators through Microsoft Entra Health Connect (assuming this component is installed). Other indicators are:

- Alerting through SIEM shows a spike when you collate the logs.
- Larger than normal log size for ADFS failed sign-ins, which can be an alert in SIEM tool).
- Increased amounts of 342/411 event IDs – username or password is incorrect. Or 516 for extranet lockout.
- Hit failed authentication request threshold – Risky IP in Microsoft Entra ID or SIEM tool alert/both 342 and 411 errors (To be able to view this information, the advanced logging should be turned on.)

Risky IP alerts occur when the customized threshold has been reached for bad passwords in an hour and bad password count in a day and extranet lockouts.



The details of failed attempts are available in the tabs **IP address** and **extranet lockouts**.

TimeStamp	Trigger Type	IP Address	Bad Password Error Count	Extranet Lockout Error Count	Unique Users Attempted
2/17/2021 5:00 PM	hour	10.10.10.10	0	17	9
2/17/2021 4:00 PM	hour	10.10.10.10	0	8	5
2/17/2021 12:00 AM	day	10.10.10.10	0	27	12
2/5/2021 7:00 AM	hour	10.10.10.10	0	6	5

Azure Identity Protection is a Microsoft Entra ID P2 feature that has a password-spray detection risk alert and search feature that provides more information or automatic remediation.

Detection time ↑↓	User ↑↓	Detection type ↑↓	Risk level ↑↓
2/23/2021, 10:16:49 AM	[REDACTED]	Password spray	High
2/18/2021, 9:43:14 PM	[REDACTED]	Password spray	High
2/18/2021, 9:09:02 PM	[REDACTED]	Password spray	High
2/18/2021, 8:27:18 PM	[REDACTED]	Password spray	High
2/17/2021, 9:21:12 AM	[REDACTED]	Password spray	High
2/10/2021, 10:25:20 AM	[REDACTED]	Password spray	High
2/6/2021, 8:55:56 AM	[REDACTED]	Password spray	High
2/4/2021, 9:23:12 AM	[REDACTED]	Password spray	High
2/3/2021, 9:34:26 AM	[REDACTED]	Password spray	High

Low and slow attack indicators are when thresholds for account lockout or bad passwords aren't being hit. You can detect these indicators through:

- Failures in GAL order
- Failures with repetitive attributes (UA, target AppID, IP block/location)
- Timing – automated sprays tend to have a more regular time interval between attempts.

Note

You can perform investigation and mitigation simultaneously during sustained/ongoing attacks.

1. Turn advanced logging on ADFS if it isn't already turned on.
2. Determine the date and time of start of the attack.
3. Determine the attacker IP address (might be multiple sources and multiple IP addresses) from the firewall, ADFS, SIEM, or Microsoft Entra ID.
4. Once password spray confirmed, you might have to inform the local agencies (police, third parties, among others).
5. Collate and monitor the following Event IDs for ADFS:

ADFS 2012 R2

- Audit event 403 – user agent making the request

- Audit event 411 – failed authentication requests
- Audit event 516 – extranet logout
- Audit Event 342 – failed authentication requests
- Audit Event 412 - Successful sign-in

6. To collect the *Audit Event 411 - failed authentication requests*, use the following [script](#):

```
PARAM ($PastDays = 1, $PastHours)
#*****
#ADFSBadCredsSearch.ps1
#Version 1.0
#Date: 6-20-2016
#Author: Tim Springston [MSFT]
#Description: This script will parse the ADFS
server's (not proxy) security ADFS
#for events which indicate an incorrectly
entered username or password. The script can
specify a
#past period to search the log for and it
defaults to the past 24 hours. Results >#will
be placed into a CSV for
#review of UPN, IP address of submitter, and
timestamp.
#*****
cls
if ($PastHours -gt 0)
{$PastPeriod = (Get-Date).AddHours(-
($PastHours))}
else
{$PastPeriod = (Get-Date).AddDays(-
($PastDays))}
```

```
$Outputfile = $Pwd.path +
"\BadCredAttempts.csv"
$CS = get-wmiobject -class win32_computersystem
$Hostname = $CS.Name + '.' + $CS.Domain
$Instances = @{}
$OSVersion = gwmi win32_operatingsystem
[int]$BN = $OSVersion.Buildnumber
if ($BN -lt 9200){$ADFSLogName = "AD FS 2.0/
Admin"}
else {$ADFSLogName = "AD FS/Admin"}
$Users = @()
$IPAddresses = @()
$Times = @()
$AllInstances = @()
Write-Host "Searching event log for bad
credential events..."
if ($BN -ge 9200) {Get-Winevent -
FilterHashTable @{LogName= "Security";
>StartTime=$PastPeriod; ID=411} -ErrorAction
SilentlyContinue | Where-Object{$_ .Message -
match "The user name or password is incorrect"}
| % {
$Instance = New-Object PSObject
$UPN = $_.Properties[2].Value
$UPN = $UPN.Split("-")[0]
$IPAddress = $_.Properties[4].Value
$Users += $UPN
$IPAddresses += $IPAddress
$Times += $_.TimeCreated
add-member -inputobject $Instance -membertype
noteproperty -name >"UserPrincipalName" -value
$UPN
```

```
add-member -inputobject $Instance -membertype  
noteproperty -name "IP Address" ->value  
$IPAddress  
add-member -inputobject $Instance -membertype  
noteproperty -name "Time" -value  
>($_.TimeCreated).ToString()  
$AllInstances += $Instance  
$Instance = $null  
}  
}  
$AllInstances | select * | Export-Csv -Path  
$Outputfile -append -force ->NoTypeInfoInformation  
Write-Host "Data collection finished. The  
output file can be found at >$outputfile`."  
$AllInstances = $null
```

Along with the above event IDs, collate the *Audit Event 1203 – Fresh Credential Validation Error*.

1. Collate all successful sign-ins for this time on ADFS (if federated). A quick sign-in and sign out (at the same second) can be an indicator of a password being guessed successfully and being tried by the attacker.
2. Collate any Microsoft Entra successful or interrupted events for this time-period for both federated and managed scenarios.

See how to find the [meaning of error logs](#).

The following Event IDs from Microsoft Entra ID are relevant:

- 50057 - User account was disabled
- 50055 - Password expired
- 50072 - User prompted to provide MFA
- 50074 - MFA required

- 50079 - user needs to register security info
- 53003 - User blocked by Conditional Access
- 53004 - Can't configure MFA due to suspicious activity
- 530032 - Blocked by Conditional Access on Security Policy
- Sign-In status Success, Failure, Interrupt

You can get all the Event IDs from the Microsoft Sentinel Playbook that is available on [GitHub](#).

Isolate the ADFS and Microsoft Entra successful and interrupted sign-in events. These are your accounts of interest.

Block the IP Address ADFS 2012R2 and above for federated authentication. Here's an example:

```
Set-AdfsProperties -AddBannedIps "1.2.3.4",
":::3", "1.2.3.4/16"
```

Collect multiple event IDs within a time frame. Here's an example:

```
Get-WinEvent -ProviderName 'ADFS' | Where-Object { $_.ID -eq '412' -or $_.ID -eq '411' -or $_.ID -eq '342' -or $_.ID -eq '516' -and $_.TimeCreated -gt ((Get-Date).AddHours(-"8")) }
```

Microsoft Entra Sign-In reports include ADFS sign-in activity when you use Microsoft Entra Connect Health. Filter sign-in logs by Token Issuer Type "Federated".

Here's an example PowerShell command to retrieve sign-in logs for a specific IP address:

```
Get-AzureADIRSignInDetail -TenantId
aaaabbbb-0000-cccc-1111-dddd2222eeee -IpAddress
```

131.107.128.76

Also, search the Azure portal for time frame, IP address and successful and interrupted sign-in as shown in these images.

Date : **Last 24 hours** Show dates as : **Local** + Add filters

Date

☐ Last 1 month

☐ Last 7 days

☐ Last 24 hours

☒ Custom time interval

Start

MM/DD/YYYY h:mm:ss A

End

MM/DD/YYYY h:mm:ss A

Apply

Application	Status
Azure Portal	Success
Azure Portal	Success
Microsoft Cloud App...	Success
Microsoft Cloud App...	Interrupted
Azure DevOps	Success
Azure Portal	Success
Azure Portal	Success

Date : **Last 24 hours** Show dates as : **Local** IP address starts with X + Add filters

IP address

192. ✓

Apply

Date	Request ID	User	Status
12/30/2020, 10:26:01...	aaaa0000-bb11-2222...	Admin	Success
12/30/2020, 10:25:58...	bbbb1111-cc22-3333...	Admin	Success

Date : **Last 1 month** Show dates as : **Local** Status : **None Selected** X + Add filters

Status

☐ Success

☐ Failure

☐ Interrupted

Apply

Date	Request ID	User	Status	IP address
------	------------	------	--------	------------

You can then download this data as a .csv file for analysis. For more information, see [Sign-in activity reports in the Microsoft Entra admin center](#).

It's important to be able to react to the most critical threat. This threat can indicate that the attacker has successfully obtained access to an account and therefore can access/exfiltrate data;

the attacker has the password but might not be able to access the account. For example, they have the password but aren't passing the MFA challenge. Also, the attacker couldn't be guessing passwords correctly but continuing to try. During analysis, prioritize these findings:

- Successful sign-ins by known attacker IP address
- Interrupted sign-in by known attacker IP address
- Unsuccessful sign-ins by known attacker IP address
- Other unknown IP address successful sign-ins

Most attacks use legacy authentication. There are many ways to determine the protocol of the attack.

1. In Microsoft Entra ID, navigate to **Sign-Ins** and filter on **Client App**.
2. Select all the legacy authentication protocols that are listed.

Date : **Last 24 hours** Show dates as : **Local** 13 selected ^

User sign-ins (interactive) User s

Date	Request ID
No sign-ins found	

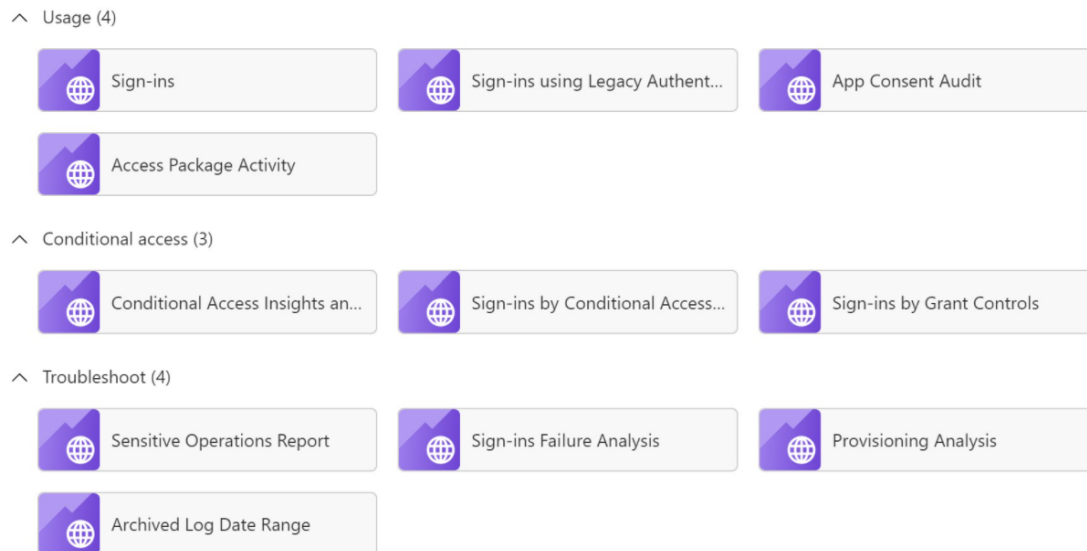
Modern Authentication Clients

- ☐ Browser
- ☐ Mobile Apps and Desktop clients

Legacy Authentication Clients

- ☒ Autodiscover
- ☒ Exchange ActiveSync
- ☒ Exchange Online Powershell
- ☒ Exchange Web Services
- ☒ IMAP
- ☒ MAPI Over HTTP
- ☒ Offline Address Book
- ☒ Other clients
- ☒ Outlook Anywhere (RPC over HTTP)
- ☒ POP
- ☒ Reporting Web Services
- ☒ SMTP
- ☒ Universal Outlook

3. Or if you have an Azure workspace, you can use the prebuilt legacy authentication workbook located in the Microsoft Entra admin center under **Monitoring and Workbooks**.



1. Navigate to **New named locations**.

New named location

[Upload](#) [Download](#)

Name *

Blocked IP Address ✓

Define the location using:

☒ IP ranges

☐ Countries/Regions

☐ Mark as trusted location ⓘ

IP ranges

Add a new IP range (ex: 40.77.182.32/27) ...

No IP ranges

2. Create a CA policy to target all applications and block for this named location only.

If they haven't and this activity is unusual, flag the user and investigate all of their activities.

Ensure you record successful passwords but failed MFA responses, as this activity indicates that the attacker is getting the password but not passing MFA.

Set aside any account that appears to be a normal sign-in, for example, passed MFA, location and IP not out of the ordinary.

It's important to also check MFA logs to determine if an attacker guessed a password but are failing the MFA prompt. The Microsoft Entra multifactor authentication logs show authentication details for events when a user is prompted for multifactor authentication. Check and make sure there are no large suspicious MFA logs in Microsoft Entra ID. For more information, see [how to use the sign-ins report to review Microsoft Entra multifactor authentication events](#).

In Defender for Cloud Apps, investigate activities and file access of the compromised account. For more information, see:

- [Investigate compromise with Defender for Cloud Apps](#)
- [Investigate anomalies with Defender for Cloud Apps](#)

Check whether the user has access to more resources, such as virtual machines (VMs), domain account permissions, storage, among others. If there's a data breach, you should inform more agencies, such as the police.

1. Change the password of any account that you suspect has been breached or the account password discovered. Additionally, block the user. Make sure you follow the guidelines for [revoking emergency access](#).
2. Mark any compromised account as "*compromised*" in Microsoft Entra ID Identity Protection.
3. Block the IP address of the attacker. Be cautious while performing this action as attackers can use legitimate VPNs and could create more risk as they change IP addresses as well. If you're using Cloud Authentication, then block the IP address in Defender for Cloud Apps or Microsoft Entra ID. If federated, you need to block the IP address at the firewall level in front of the ADFS service.

4. [Block legacy authentication](#) if it's being used (this action, however, could impact business).
5. [Enable MFA](#) if it isn't already done.
6. [Enable Identity Protection](#) for the user risk and sign-in risk
7. Check the compromised data (emails, SharePoint, OneDrive, apps). See how to use the [activity filter in Defender for Cloud Apps](#).
8. Maintain password hygiene. For more information, see [Microsoft Entra password protection](#).

Implement password protection on Microsoft Entra ID and on-premises by enabling the custom-banned password lists. This configuration prevents users from setting weak passwords or passwords associated with your organization:

The screenshot shows the 'Authentication methods | Password protection' page in the Microsoft Entra admin center. The page is titled 'Authentication methods | Password protection' with a key icon and a link icon. Below the title is the text '- Azure AD Security'. The left sidebar has a search bar and a 'Manage' section with 'Policy' and 'Password protection' (selected). The main content area has a top bar with 'Save', 'Discard', and 'Got feedback?' buttons. The configuration is divided into sections: 'Custom smart lockout' with 'Lockout threshold' (10) and 'Lockout duration in seconds' (60), both with green checkmarks; 'Custom banned passwords' with 'Enforce custom list' (Yes) and 'Custom banned password list' (contoso, fabrikam, wolverine, howard, northwind, michigan) with a green checkmark; and 'Password protection for Windows Server Active Directory' with 'Enable password protection on Windows Server Active Directory' (Yes) and 'Mode' (Enforced).

Authentication methods | Password protection [✕](#)

- Azure AD Security

Search (Ctrl+/) << Save Discard Got feedback?

Manage

- Policy
- Password protection**

Custom smart lockout

Lockout threshold ⓘ 10 ✓

Lockout duration in seconds ⓘ 60 ✓

Custom banned passwords

Enforce custom list ⓘ Yes No

Custom banned password list ⓘ

contoso
fabrikam
wolverine
howard
northwind
michigan ✓

Password protection for Windows Server Active Directory

Enable password protection on Windows Server Active Directory ⓘ Yes No

Mode ⓘ Enforced Audit

For more information, see [how to defend against password spray attacks](#).

Tag the IP addresses in Defender for Cloud Apps to receive alerts related to future use:

Activity log

1 - 1 of 1 activities

Investigate in Activity log

Activity	User	App	IP address	Location	Device	Date
Failed log on (Failure message: This error occurred due t...		Office 365	192.68.			Apr 1, 2020, 12:54 PM

SHOW SIMILAR

General User **IP address** Send us feedback...

192.68.11.219
RISKY IP ADDRESS

Tags: TOR, ANONYMOUS PROXY
ISP: D:

OPEN ALERTS: 1
ACTIVITIES: 0
ADMIN ACTIVITIES: 0

IP ACTIVITIES (30 DAYS) See all

IP LOCATION: Location is not available for this IP address

Filter by this IP address

IP address actions ^

- Tag as a Corporate IP and add to whitelist
- Tag as a VPN IP and add to whitelist
- Tag as a Risky IP and add to blacklist

Tagging IP addresses

In Defender for Cloud Apps, "tag" IP address for the IP scope and set up an alert for this IP range for future reference and accelerated response.

Policy template *

Logon from a risky IP address

Policy name *

Password Spray

Policy severity *

Category *

Threat detection

Description

Alert when a user logs on from a risky IP address to your sanctioned services. 'Risky' IP category contains by default anonymous proxies and TOR exits point. You can add more IP addresses to this category through the 'IP addresses range' settings page.

Create filters for the policy

Act on:

- ☒ Single activity
Every activity that matches the filters
- ☐ Repeated activity:
Repeated activity by a single user

ACTIVITIES MATCHING ALL OF THE FOLLOWING

Edit and preview results

IP address Raw IP address equals

1.2.3.4

+

+

Setting alerts for a specific IP address

Depending on your organization needs, you can configure

alerts.

[Set up alerting in your SIEM tool](#) and look at improving logging gaps. Integrate ADFS, Microsoft Entra ID, Office 365 and Defender for Cloud Apps logging.

Configure the threshold and alerts in ADFS Health Connect and Risky IP portal.

Threshold Settings ×

 Save  Discard ...

(Bad U/P + Extranet Lockout)/Day * ⓘ

(Bad U/P + Extranet Lockout)/Hour * ⓘ

Extranet Lockout - Day * ⓘ

Extranet Lockout - Hour * ⓘ

Notification Settings ×

 Save  Discard

Get email notification for new alerts

☒ ON ☐ OFF

Get email notifications for IP addresses exceeding failed activity threshold report

☐ ON ☒ OFF

Recipients

☒ Notify All Global Administrators

A screenshot of a web form. At the top, there are two buttons: 'Insert' with a plus icon and 'Delete' with a trash can icon. Below these buttons is a label 'Email Address' followed by a text input field.

See how to [configure alerts in the Identity Protection portal](#).

- [Configure Sign-In risk](#)
- [Configure User Risk](#)
- [Configure policy alerts in Defender for Cloud Apps](#)
- Educate end users, key stakeholders, frontline operations, technical teams, cyber security and communications teams
- Review security control and make necessary changes to improve or strengthen security control within your organization
- Suggest Microsoft Entra configuration assessment
- Run regular [attack simulator](#) exercises
- [Microsoft Sentinel Alerting](#)
- [SIEM integration into Defender for Cloud Apps](#)
- [SIEM integration with Graph API](#)
- [Splunk alerting manual](#)
- [Installing ADFS Health Connect](#)
- [Understanding Microsoft Entra sign-in logs](#)
- [Understanding MFA reporting](#)
- [Mitigations for password spray](#)
- [Enable password protection](#)
- [Block legacy authentication](#)
- [Block IP address on ADFS](#)
- [Access controls \(including blocking IP addresses\) ADFS v3](#)

- [ADFS Password Protection](#)
- [Enable ADFS Extranet Lockout](#)
- [MFA as primary authentication](#)
- [Enable Identity Protection](#)
- [Microsoft Entra audit activity reference](#)
- [Microsoft Entra audit logs schema](#)
- [Microsoft Entra sign-in logs schema](#)
- [Microsoft Entra audit log Graph API](#)
- [Risky IP Alerts](#)
- [SIEM tool integrations](#)
- [Create Defender for Cloud Apps alerts](#)
- [Create Risky IP and ADFS Health Connect Alerts](#)
- [Identity Protection alerts](#)
- [Attack simulator](#)

Examine guidance for identifying and investigating these extra types of attacks:

- [Phishing](#)
- [App consent](#)
- [Overview](#) for Microsoft security products and resources for new-to-role and experienced analysts
- [Planning](#) for your Security Operations Center (SOC)
- [Microsoft Defender XDR](#) incident response
- [Microsoft Defender for Cloud \(Azure\)](#)
- [Microsoft Sentinel](#) incident response

- [Microsoft Incident Response team guide shares best practices for security teams and leaders](#)
- [Microsoft Incident Response guides help security teams analyze suspicious activity](#)